La Machine Nibbles :



Nom : Nibbles
Difficulty : easy
Points : 20 - 480 xp
Release : 13 Janvier 2018
OS : Linux

Pour nos besoins et pour bien commencer ce CPTS path nous allons parcourir la machine Nibbles, étapes par étapes de la reconnaissance au root...

La Reconnaissance :

Avant de lancer notre premier scan, rappellons qu'il est essentiel de conserver des journaux horodatés détaillés des tentatives de scan et d'exploitation en cas de panne ou d'incident pour lequel le client à besoin d'informations sur nos activitées.

- Lançons alors premièrement notre scan nmap :
  - nmap -sV -oG nmapformatgrep.txt 10.129.96.84

Les options utilisées sont -sV qui énumèrent les numéros de versions des services utilisées. Et -oG qui sauvegarde le résultat dans un fichier texte structuré de manière à être facilement analysable avec des outils en ligne de commande comme "grep", "awk" ou "cut"; ce format est dit "greppable". Ce format est très pratique pour extraire rapidement des informations spécifiques (par exemple lister toutes les IP dont le port 80 est ouvert).

- D'après la sortie du scan initial, nous pouvons voir que l'hôte est probablement un linux Ubuntu et expose un serveur web Apache sur le port 80 et un serveur OpenSSH sur le port 22.

- Avant de commencer à fouiller les ports ouverts, nous pouvons lancer un scan complet des ports TCP en utilisant l'option -p- cet option scan les 65 389 ports, du coup le scan met un peu de temps, et aucun port supplémentaire n'est découvert.

- N'oublions pas le bannière grabbing avec nmap et -sv pour le verbeux et le n pour désactiver la résolution DNS cet options est aussi intéressante pour la furtivité. Rien ici ni pour le port 22 ni pour le port 80 nous n'avons d'information intéressante.

- On peu aussi alors utilisé un scan nmap avec l'option -sC qui utilise des scripts par défault attention ceux-ci sont très intrusif. On peu aussi au vue de l'application web présente sur la cible utilisé le script http-enum avec l'option --script=http-enum

La reconnaissance Web :

- En premier lieu utilisons whatweb suivi de l'IP ou du domain la commande n'identifie ici aucune technologie web standard a part. La version du serveur Apache cible - 2.4.18 et le code de retour du serveur qui est 200.

- Ensuite on peu contrôler rapidement le code source de l'application web via F12 ou Ctrl + U ou curl http://ip. On a un commentaire de code interessant <!- nibbleblog Directory. Nothing interesting here! --> on peu de nouveau exécuter un whatweb cette fois sur ip/nibbleblog, le repertoire mentionné dans le commentaire, cette fois on a une meilleur idée